

Rencana Team Account dan Pusat Konflik KRON

Dokumen desain implementasi | KRON

Daftar isi

- Status dan tujuan
- Fondasi Google Drive tanpa backend
- Role dan batas wewenang
- Undangan dan kode akses
- Model data dan migrasi
- Snapshot Team dan isolasi akun
- Konversi privat menjadi Team
- Konversi Team menjadi privat
- Offline edit dan snapshot DAG
- Pusat Konflik baru
- Antarmuka implementasi yang direncanakan
- UI dan UX
- Pengujian dan release gate

Status dan tujuan

Dokumen ini menetapkan rancangan Team Account tanpa server backend serta peningkatan Pusat Konflik untuk sinkronisasi Drive privat dan Team. Implementasi harus mempertahankan lima tab KRON, kompatibilitas data produksi sejak 1.0.21, enkripsi database, audit append-only, dan seluruh invariant finansial.

Fase pertama tidak mencakup Wallet bersama, ownership transfer, group atau domain permission, link publik, kode akses pendek, QR code, chat, maupun notifikasi server.

Fondasi Google Drive tanpa backend

Sync privat tetap memakai `appDataFolder`. Team Account memakai satu folder Google Drive yang terlihat per akun dengan scope non-sensitive <https://www.googleapis.com/auth/drive.file>, diminta hanya ketika pengguna membuat atau bergabung ke Team.

`appDataFolder` tidak dapat dibagikan, sehingga snapshot privat yang sekarang tidak boleh dipakai untuk Team. Referensi resmi:

- [Google Drive appDataFolder](#)
- [Google Drive OAuth scopes](#)
- [Google Drive sharing dan ACL](#)

Owner membuat folder Team melalui KRON dan menambahkan satu email Google tertentu sebagai `reader` atau `writer`. Folder harus memakai `writersCanShare=false`. Role dan `capabilities` dari Drive adalah otoritas akhir. Cache lokal tidak pernah boleh menaikkan hak yang ditolak Drive.

Implementasi dimulai dengan spike dua akun Google nyata untuk membuktikan folder yang dibuat OAuth app KRON dapat diakses akun penerima dengan `drive.file`. Jika gagal, fitur diblokir. Jangan menggantinya dengan permission `anyone`, link publik, atau scope Drive penuh.

Role dan batas wewenang

Role Team hanya:

- **OWNER**: seluruh operasi akun, collaborator, role, undangan, revoke, dan konversi Team kembali ke privat.
- **EDITOR**: transaksi, budget, portfolio, automation, bukti, reversal, restore, dan export laporan akun. Tidak dapat mengelola member, role, undangan, atau konversi.
- **VIEWER**: melihat akun dan laporan di aplikasi. Seluruh write, automation, backup, export, sharing, reversal, dan restore diblokir.

Owner melihat collaborator dari `permissions.list`, dibatasi ke permission `type=user`. Perubahan role memanggil `permissions.update`; penghapusan member memanggil `permissions.delete`. UI harus memeriksa Drive capabilities sebelum menampilkan tindakan Owner.

Penghapusan member mencabut akses Drive dan mencegah akses snapshot berikutnya. KRON harus menjelaskan bahwa data yang sudah pernah dilihat atau diunduh pada device member tidak dapat dihapus paksa tanpa backend.

Undangan dan kode akses

Owner memasukkan email Google member dan memilih **EDITOR** atau **VIEWER**. Setelah ACL Drive berhasil dibuat, KRON menghasilkan kode akses sekali pakai:

```
KRONTTEAM1.<base64url-payload>
```

Payload versioned memuat **teamId**, **folderId**, **inviteId**, secret acak 256-bit, SHA-256 email tujuan yang sudah dinormalisasi, role, masa berlaku 24 jam, dan fingerprint kunci Owner. Kode harus dapat disalin dan ditempel, diperlakukan seperti password, dan tidak disimpan pada log, analytics, backup, clipboard permanen, atau Room.

Folder menyimpan invitation envelope yang:

- mengandung team key acak 256-bit;
- dienkripsi AES-256-GCM dengan kunci hasil HKDF-SHA256 dari secret undangan;
- ditandatangani dengan kunci bukti Owner;
- memuat identitas undangan, role, email hash, expiry, dan fingerprint Owner;
- dihapus setelah join berhasil atau dibatalkan Owner.

Saat join, member memilih akun Google, memberi scope **drive.file**, memasukkan kode, lalu KRON memverifikasi format, expiry, email, ACL, signature Owner, dan replay sebelum memasang team key ke envelope Android Keystore lokal. Device kedua milik member yang sama membutuhkan kode baru.

Model data dan migrasi

Jika schema produksi masih 14 saat implementasi dimulai, tambahkan hanya **MIGRATION_14_15**. Jika sudah bertambah, gunakan migrasi **N -> N+1** berikutnya. Jangan mengubah migrasi yang pernah dikirim dan jangan memakai destructive fallback.

Perubahan model yang direncanakan:

- **accounts**: **sharingMode** dengan nilai **PRIVATE** atau **TEAM**, serta **teamId** nullable dan unik untuk akun Team.
- **team_workspaces**: relasi ke account, team ID, folder ID, role lokal, owner subject hash, head snapshot, generation, status sync, dan waktu archive.
- **team_members**: cache permission ID, email, display name, role, status, dan waktu refresh untuk UI Owner. Cache ini bukan otoritas.
- Stable **syncId**, **revision**, **updatedAt**, dan **lastWriterId** pada entity mutable yang perlu dibandingkan lintas device.
- Kategori mendapat scope akun nullable. Data lama tetap global; konversi Team mengkloning kategori yang direferensikan akun agar perubahan Team tidak memengaruhi akun privat.
- Team sync state disimpan per workspace, terpisah dari singleton **sync_state** privat.
- Team key hanya berada dalam envelope Android Keystore versioned, bukan dalam Room, manifest, atau log.

Event UUID, recurring rule UUID, dan receipt **storageId** dipertahankan. Entity dengan ID integer lokal dipertukarkan memakai stable **syncId**; importer memetakan ID lokal dalam staging dan tidak mempercayai primary key dari device lain.

Snapshot Team dan isolasi akun

Snapshot Team hanya berisi graph milik satu account:

- account dan kategori scoped;
- portfolio, period, allocation, template, dan recurring rule;
- activity event, cash dan budget journal, split, occurrence, dan audit;
- ledger rows, seal, actor, serta evidence key yang direferensikan;

- receipt dan metadata bukti.

Tidak satu pun nama, nilai, identifier, metadata, key, atau attachment akun privat lain boleh masuk payload Team, `appProperties`, nama file, atau diagnostic log.

Snapshot bersifat immutable dan diunggah sebagai file baru. Protokol v2 memakai `parentSnapshotIds` agar hasil merge dapat memiliki dua parent. Decoder protocol v1 tetap dipertahankan untuk sync privat lama.

Attachment disimpan sebagai blob terenkripsi content-addressed berdasarkan SHA-256 di dalam folder Team. Snapshot hanya mereferensikan blob, sehingga bukti tidak diunggah ulang. Blob diunggah dan diverifikasi sebelum snapshot yang mereferensikannya. Garbage collection hanya boleh menghapus blob yang tidak direferensikan snapshot aktif maupun recovery setelah masa retensi.

Automatic Drive backup privat mengecualikan row Team, cache collaborator, team key, dan blob Team. Backup portable Team hanya boleh dibuat Owner. Editor tetap dapat membuat CSV, PDF, dan paket bukti account-scoped.

Konversi privat menjadi Team

Konversi harus berjalan sebagai transaksi staging:

1. Pastikan tidak ada sync, restore, automation, atau write aktif.
2. Buat dan verifikasi backup serta private rollback copy database, WAL, SHM, key metadata, dan receipt.
3. Generate team ID, team key, stable sync IDs, dan kategori account-scoped dalam kandidat.
4. Ekspor hanya graph akun target dan validasi tidak ada data akun lain.
5. Buat folder Drive, upload blob bukti dan genesis snapshot, lalu verifikasi download serta checksum.
6. Jalankan Room schema validation, SQLite integrity, foreign key, signature, account isolation, ledger balance, Cash, eBudget, Vault, budget, allocation, dan receipt invariants.
7. Aktifkan `sharingMode=TEAM` secara atomik hanya setelah remote dan kandidat lolos.
8. Pada kegagalan, karantina kandidat dan pulihkan data sumber byte-for-byte.

Konversi Team menjadi privat

Hanya Owner yang dapat menjalankan konversi dan harus online:

1. Pastikan tidak ada konflik dan terapkan head Team terbaru.
2. Freeze write Team dan tulis tombstone konversi.
3. Buat backup dan kandidat privat account-scoped.
4. Validasi seluruh invariant serta attachment sebelum aktivasi lokal.
5. Ubah akun menjadi privat secara atomik dan keluarkan dari Team sync.
6. Cabut semua ACL non-Owner dan ubah workspace menjadi owner-only.
7. Pertahankan workspace selama 30 hari untuk rollback, lalu tawarkan penghapusan permanen kepada Owner.

Member yang kehilangan ACL menandai akun Team sebagai revoked pada sync berikutnya dan menghapus cache operasional setelah konfirmasi. Tidak ada klaim bahwa KRON dapat menghapus salinan offline secara paksa.

Offline edit dan snapshot DAG

Editor boleh bekerja offline berdasarkan role terakhir yang telah diverifikasi. Setiap perubahan menghasilkan generation lokal dan actor metadata berupa Drive permission ID, device ID, serta timestamp. Email tidak dimasukkan ke audit payload atau log.

Saat online, KRON mengunduh semua active head untuk team ID:

- satu head dan parent cocok: lanjut upload atau download normal;
- dua head dengan perubahan terpisah: buka Pusat Konflik dan siapkan safe merge;
- head berubah selama review: batalkan resolusi dan muat ulang;
- ACL menolak write: jangan upload, ubah role efektif, dan pertahankan perubahan lokal sebagai recovery sampai pengguna meninjau konflik.

Tidak ada update in-place pada snapshot. Retensi mempertahankan active heads, parent yang diperlukan, hasil merge, dan recovery yang dilindungi konflik.

Pusat Konflik baru

Pusat Konflik menggantikan dialog snapshot lama untuk sync privat dan Team. Sebelum menampilkan keputusan, KRON:

1. mengunduh dan mendekripsi remote ke staging read-only;
2. memvalidasi package, schema, integrity, foreign key, signature, dan invariant finansial;
3. membangun canonical fingerprint lokal serta remote;
4. menghasilkan preview tanpa mengaktifkan data remote.

UI berupa layar penuh dengan ringkasan jumlah dan nominal serta filter:

- hanya di perangkat;
- hanya di Drive;
- identik;
- benar-benar berbeda;
- masalah integritas.

Setiap row transaksi menampilkan tanggal, tipe, judul, nominal, account, status reversal, jumlah bukti, actor, device, dan waktu perubahan. Detail boleh menampilkan journal impact dan hubungan correction/reversal, tetapi tidak menulis payload sensitif ke log.

Gabungkan aman

Gabungkan aman menjadi tindakan utama:

- event digabung berdasarkan UUID dan canonical hash;
- event yang hanya ada di satu sisi di-union;
- correction, reversal, related event, journal, split, audit, seal, dan receipt diperlakukan sebagai satu graph atomik;
- entity mutable digabung otomatis bila hanya satu sisi berubah dari base revision;
- bila kedua sisi mengubah stable entity yang sama, pengguna memilih versi lokal atau Drive untuk item tersebut;
- attachment dideduplicasi berdasarkan storage ID dan SHA-256; file hilang tidak menghapus metadata.

Event dengan UUID sama tetapi payload, canonical hash, atau signature berbeda dianggap masalah integritas. Jangan izinkan merge maupun overwrite. Karantina kedua kandidat dan pertahankan recovery copy.

Sebelum mengaktifkan hasil merge:

1. buat recovery snapshot lokal dan Drive;
2. bangun kandidat di staging;
3. jalankan seluruh validasi database, audit, scope, dan finansial;
4. pastikan remote head belum berubah;
5. aktifkan kandidat secara atomik;
6. upload merge snapshot dengan semua head sumber sebagai parent.

Ops seluruh snapshot

Opsi berikut tetap tersedia dalam bagian lanjutan setelah preview selesai:

- Amankan kedua versi;
- Gunakan perangkat ini;
- Gunakan Drive.

Masing-masing harus menjelaskan data yang menjadi aktif dan recovery yang dibuat. Opsi seluruh snapshot tidak boleh menjadi tindakan utama atau dijalankan sebelum passphrase, preview, dan remote head tervalidasi.

Antarmuka implementasi yang direncanakan

Tipe domain minimum:

- AccountSharingMode: PRIVATE, TEAM.
- TeamRole: OWNER, EDITOR, VIEWER.
- TeamWorkspace, TeamMember, TeamInvitation, dan TeamCapability.
- ConflictPreview, ConflictItem, ConflictChoice, dan MergePlan.
- Drive snapshot manifest v2 dengan parentSnapshotIds.

Boundary minimum:

- Team Drive client untuk folder, child files, capabilities, dan permission CRUD.
- Account-scoped snapshot exporter/importer yang selalu memakai staging.
- Team access guard tunggal yang dipanggil semua repository write, automation, restore, dan export.
- Conflict preview builder dan safe merge executor bersama untuk privat dan Team.

Gunakan REST client, crypto, backup staging, canonicalizer, dan invariant validator yang sudah ada. Jangan menambah backend, database network, framework sync, atau abstraction dengan satu implementasi tanpa kebutuhan nyata.

UI dan UX

Lima tab tetap dipertahankan. Pengaturan akun aktif menampilkan status **Privat** atau **Team**, role, status sync, dan entry point:

- Ubah menjadi **Team** untuk akun privat;

- **Collaborator** dan **Buat kode akses** untuk Owner;
- **Masukkan kode akses** untuk join;
- **Tinggalkan Team** untuk member tanpa membuat copy privat;
- **Kembalikan menjadi privat** untuk Owner.

Viewer melihat write controls dalam keadaan hidden atau disabled dengan alasan yang jelas. Editor tidak melihat member management. Semua dialog berisi validasi dekat input, state rotasi, target sentuh minimal 48 dp, content description, serta layout font scale 1.0 sampai 1.5.

Pengujian dan release gate

Pengujian minimum:

- migration test schema sebelumnya ke schema Team tanpa perubahan nilai atau jumlah row lama;
- conversion privat ke Team ke privat dengan rollback pada setiap fase;
- payload isolation test yang membuktikan akun privat tidak ikut;
- dua akun Google nyata untuk invite, wrong email, expiry, replay, role, revoke, dan capabilities;
- viewer write/export denial dan editor member-management denial pada UI serta repository;
- offline multi-writer: auto-merge event berbeda, conflict entity mutable, reversal graph, dan remote head berubah saat review;
- corruption: UUID sama dengan hash berbeda, signature gagal, attachment rusak atau hilang;
- low storage, process death, auth expiry, revoked ACL, Drive quota, dan jaringan terputus;
- backup round-trip, install-over versi produksi sebelumnya, schema validation, lint, release build, dan signature verification;
- UI test Owner, Editor, Viewer, Pusat Konflik, rotasi, font scale, dan accessibility.

Fitur tetap di balik build-time feature flag sampai spike **drive.file**, migration, conversion rollback, account isolation, safe merge, dan dua akun Drive lulus. Kegagalan salah satu gate memblokir rilis Team Account dan tidak boleh menurunkan keamanan dengan scope atau permission yang lebih luas.